Лабораторная работа: РБПО

Индивидуальная работа • C++ • Максимальная оценка: 10 баллов

Подготовить приложение

Обязательно используйте LLM для генерации C++-кода. Тема приложения свободная. В промпте потребуйте: приложение с вводом из файла или stdin; минимум две намеренные ошибки безопасности разных типов, включая ошибку памяти; минимум одну реально используемую стороннюю зависимость фиксированной версии с известной CVE. Приложение должно собираться и выполнять свою основную функцию.

Сохраните название LLM, промпт и исходный сгенерированный код. Ошибки, версии зависимостей и CVE, предложенные LLM, проверьте самостоятельно. Исходную дефектную версию сохраните отдельно от исправленной.

Оценка

Уровни накопительные: каждый следующий включает предыдущие. Инструменты выбираете сами; повторные запуски одного инструмента не увеличивают их количество.

Баллы	Выполненный уровень
4/10	Один статический анализатор (SAST).
5/10	Два разных SAST, сравнение результатов.
6/10	Три разных SAST, сравнение результатов.
7/10	Всё на 6 + один композиционный анализатор (SCA).
8/10	Всё на 7 + второй SCA, сравнение результатов.
10/10	Всё на 8 + фаззинг приложения с AFL++.

Что выполнить

SAST. Сохранить команды, версии инструментов и отчёты. Для уникальных находок указать место, причину, CWE, статус TP/FP и обоснование. Отметить пропущенные намеренные ошибки. Исправить подтверждённые дефекты и повторить анализ.

SCA. Зафиксировать состав и версии зависимостей, получить SBOM. Разобрать CVE и их применимость к приложению. Обновить уязвимую зависимость, проверить сборку и поведение, повторить SCA. Для двух инструментов сравнить результаты.

AFL++. Подготовить инструментированную сборку с ASan и начальный корпус, запустить фаззинг, сохранить команды, параметры и статистику. Найденный сбой воспроизвести, объяснить и исправить; сохранить вход для повторной проверки. Указать проверявшуюся версию приложения.

Во всех этапах для каждой подтверждённой проблемы найти материал **OWASP** и запись **БДУ ФСТЭК**: привести ссылки и объяснить связь. Для CWE и сбоя ищется аналогичный случай, для CVE - запись о той же уязвимости. Если соответствие не найдено, описать поиск; идентификаторы не выдумывать.

Что сдать

Исходная и исправленная версии проекта, инструкция сборки, промпт и название LLM, команды и отчёты инструментов, краткая таблица разбора с OWASP/БДУ. Для SCA добавить SBOM, для AFL++ - корпус, статистику и найденные сбойные входы.

Количество инструментов задаёт максимальную оценку; балл зависит от корректности и полноты работы. Отсутствие сбоев в AFL++ допустимо при подтверждённой работе кампании и объяснении её охвата.

Источники: cwe.mitre.org · owasp.org · bdu.fstec.ru